

Technický popis

TORKIS

Přihlášení do aplikace a zabezpečení dat

Verze aplikace 5.1.8 • Stav k 4. 6. 2026 • Firebase projekt `visto-51cb7`

1. Přehled

Aplikace TORKIS používá pro ověřování uživatelů službu **Firebase Authentication** a data ukládá do **Cloud Firestore**. Přístup k datům je řízen ve dvou vrstvách:

- Identita** — kdo je uživatel (přihlášení e-mailem, Googlem, Apple ID, biometrické odemčení).
- Autorizace** — k jakým datům smí. Vynucují ji **bezpečnostní pravidla Firestore** na serveru, takže je nelze obejít úpravou aplikace.

Každý uživatel patří k jednomu **servisu** (identifikátor `servis_id`). Vidí a upravuje pouze data svého servisu.

2. Způsoby přihlášení

Metoda	Platforma	Popis
E-mail a heslo	iOS, Android, web	Klasická registrace i přihlášení. Hesla spravuje Firebase (nikdy se neukládají v čitelné podobě).
Google	iOS, Android	Přihlášení Google účtem (balíček <code>google_sign_in</code> → ověření tokenu ve Firebase).
Apple ID	iOS	Nativní „Sign in with Apple“ (<code>signInWithProvider</code>). Na Androidu se nenabízí.
Biometrie (Face ID / otisk)	iOS, Android	Rychlé opětovné přihlášení a zámek aplikace. Volitelné, zapíná se v nastavení.

Biometrické přihlášení — jak funguje

Biometrie **nenahrazuje** přihlášení, ale zrychluje opětovný vstup. Při zapnutí se po prvním přihlášení heslem uloží přihlašovací údaje do **šifrovaného úložiště zařízení** (`flutter_secure_storage` — na iOS Keychain, na Androidu KeyStore). Při dalším spuštění aplikace ověří otisk/obličej přes systém a údaje použije k tichému přihlášení. Bez úspěšného biometrického ověření se do aplikace nedostane.

3. Tok přihlášení (kontrola při spuštění)

O směřování se stará komponenta **AuthGate**, která naslouchá stavu přihlášení z Firebase:

1. Nepřihlášen → zobrazí se přihlašovací obrazovka.

2. Anonymní relace (ze zákaznického portálu) → automaticky odhlášena, zobrazí se přihlášení.

3. Přihlášen, ale bez profilu → spustí se průvodce prvním nastavením (onboarding).

4. Přihlášen s profilem → načtou se údaje servisu, role a oprávnění, ověří se předplatné a aktivuje se biometrický zámek (pokud je zapnutý).

5. Neaktivní předplatné / trial → zobrazí se obrazovka s předplatným (paywall).

4. Registrace a první nastavení (onboarding)

Nový uživatel (bez profilu v databázi) projde průvodcem, který:

- založí **servis** a jeho nastavení (název, IČO/ARES, kontakt, automatizace),
- vytvoří **účet majitele** s rolí `admin` a právem spravovat zaměstnance,
- přednastaví katalog úkonů,
- založí **30denní zkušební období** (trial) zdarma bez platební karty.

Tento postup je shodný pro registraci e-mailem i pro první přihlášení přes Google/Apple.

5. Vícuživatelský model

K jednomu servisu může patřit více uživatelů. Profil každého uživatele (kolekce `uzivatele`) obsahuje:

- `servis_id` — ke kterému servisu patří (u zakladatele se rovná jeho vlastnímu ID),
- `role` — např. `admin` nebo `zamestnanec`,
- `prava` — jemnější oprávnění, např. správa zaměstnanců a nastavení.

Zaměstnance přidává správce s právem `zamestnanci`; nový účet dostane stejné `servis_id`, takže okamžitě vidí vozidla, zákazníky a zakázky servisu.

6. Zabezpečení dat (pravidla Firestore)

Pravidla běží **na serveru Google** a platí pro každý přístup k datům — i kdyby se někdo pokusil obejít aplikaci a připojit se k databázi přímo. Klíčové principy:

Izolace servisu

U datových kolekcí (`vozidla`, `zakaznici`, `zakazky`, `ukony`, `faktury`, `vin_skeny`, `value_skeny`, `nastaveni_servisu`) platí: **číst a zapisovat smí jen člen příslušného servisu**. Server odvodí `servis_id` volajícího z jeho profilu a porovná ho s daty. Cizí servis je zcela nepřístupný.

Role a oprávnění

- Běžný uživatel pracuje pouze s daty svého servisu.
- Správu zaměstnanců (přidání/úprava/odebrání účtů) smí jen uživatel s právem `zamestnanci`.
- Vlastník aplikace má vyhrazená oprávnění pro ruční správu předplatného.

Ochrana proti zneužití (eskalaci práv)

Uživatel si **nemůže** sám změnit své `servis_id`, `role` ani `prava` — tím je zablokováno „povýšení sebe sama“ nebo přeskočení do cizího servisu. Cizí profily ve svém servisu mění jen pověřený správce.

Serverové kolekce (jen backend)

Citlivé kolekce, které určují limity placených funkcí — počítadlo využití (`pouziti`), cache VIN a tržní hodnoty (`vin_cache` , `value_cache`) a placené plány (`predplatne`) — **klient nesmí zapisovat**. Mění je pouze backend (Cloud Functions) a ověřené webhooky, aby nešlo limity obejít.

Předplatné a trial

Klient smí založit jen **zkušební** plán (při onboardingu). Placené plány zapisuje výhradně platební systém (RevenueCat) přes serverový webhook. Aktivnost předplatného se ověřuje při každém přihlášení; bez platného plánu/trialu se zobrazí paywall.

Zákaznický portál (anonymní přístup)

Zákazník servisu může přes odkaz s jednorázovým tokenem anonymně otevřít svou zakázku, schválit/zamítnout nacenění a posílat zprávy. Tento anonymní přístup je **striktně omezen** jen na danou zakázku a její zprávy — k žádným jiným datům (zákazníci, faktury, nastavení) se nedostane.

7. Backend (Cloud Functions)

Serverové funkce běží s administrátorským oprávněním (Admin SDK), které pravidla obchází, ale je dostupné jen Googlem ověřenému serverovému prostředí — ne klientovi. Funkce řeší např. počítání využití drahých API a zpracování plateb.

8. Co zatím není vynuceno (doporučení do budoucna)

- **Ověření e-mailu** — aplikace zatím nevyžaduje potvrzení e-mailové adresy. Vhodné doplnit pro registraci e-mailem.
- **SHA-1 pro Google na Androidu** je aktuálně z ladicího (debug) klíče. Před vydáním na Google Play je nutné přidat SHA-1 z „Play App Signing“.
- **Správa zaměstnanců na úrovni rolí** je vázaná na právo `zamestnanci`; případné jemnější rozlišení (více úrovní rolí) lze doplnit.

Shrnutí: Identitu řeší Firebase (e-mail, Google, Apple, biometrie), autorizaci vynucují serverová pravidla Firestore s úplnou izolací mezi servery, ochranou proti eskalaci práv a serverově chráněnými kolekcemi pro placené funkce.

TORKIS — interní technický popis přihlášení a zabezpečení. Vygenerováno 4. 6. 2026. Dokument popisuje aktuální stav implementace a může se s vývojem aplikace měnit.